PUBLIC KEY INFRASTRUCTURE

S04: Thu hồi Chứng chỉ & Quản lý Khóa bằng Phần cứng HSM

Nguyen An Khuong, *CSE-HCMUT*
ORCID: 0000-0002-9910-6387 · Email: nakhuong@hcmut.edu.vn

Ho Chi Minh City University of Technology (HCMUT), VNU-HCM
Faculty of Computer Science and Engineering
Teaching Assistant: Mr. Nguyen Huu Hoang Huy (LinkedIn Profile)

Session 4 of 9 · ATHK 512 (KMA CHAT4P, HK261)
Class: Sat 24/10/2026 · 13h30–18h30
Standards: IETF RFC 5280, RFC 6960 (OCSP), FIPS 140-3, PKCS#11

1. Tổng quan & Lộ trình Buổi S04

Lộ Trình Học Phần (Buổi 4/9)

S01: Architecture, Trust & Threat Models	S02: X.509, ASN.1 & Path Validation	S03: CA Lifecycle & ACME Protocol
S04: Revocation (CRL/OCSP) & Hardware HSM	S05: TLS 1.3 & mTLS Zero Trust Gateway	S06: Certificate Transparency (CT) Logs & Merkle Tree
S07: PQC Migration NIST FIPS 203/204	S08: Enterprise AD CS Attack & Defense	S09: Capstone Defense & Audit Synthesis

Buổi học giải quyết bài toán xử lý rủi ro khi khóa bí mật bị thỏa hiệp: cơ chế thu hồi tức thì và giải pháp bảo vệ khóa bí mật ở cấp độ phần cứng bằng thiết bị HSM chuyên dụng.

Chuẩn Đầu Ra Buổi Học S04 (Learning Objectives)

Sau buổi học S04, học viên làm chủ các năng lực:

1. **So sánh** ưu nhược điểm kỹ thuật giữa CRL tĩnh, máy chủ OCSP và công nghệ OCSP Stapling.
2. **Phân tích** cơ chế tấn công Soft-fail và biện pháp phòng vệ bằng chuẩn OCSP Must-Staple (RFC 7633).
3. **Đánh giá** tiêu chuẩn an ninh phần cứng HSM theo NIST FIPS 140-3 từ Level 1 đến Level 4.
4. **Cấu hình** môi trường phần mềm trung gian PKCS#11 và tích hợp SoftHSMv2 với OpenSSL 3.5.

Nguyên Tắc Bất Đối Xứng Của Rủi Ro. Cấp chứng chỉ thì dễ, nhưng thu hồi chứng chỉ một cách an toàn, nhanh chóng và bảo đảm quyền riêng tư người dùng lại là một trong những bài toán phức tạp nhất của ngành mạng!

2. Cơ chế Thu hồi: CRL vs OCSP vs OCSP Stapling

So Sánh Kỹ Thuật 3 Cơ Chế Kiểm Tra Thu Hồi

Tiêu Chí	CRL (RFC 5280)	OCSP (RFC 6960)	OCSP Stapling (RFC 6066)
Phương thức	File nhị phân tĩnh HTTP	Truy vấn nhị phân HTTP	Kẹp kèm trong TLS Handshake
Kích thước	Rất nặng (hàng chục MB)	Nhẹ (vài trăm bytes)	Không tốn thêm kết nối ngoài
Riêng tư	Tốt (CA không biết ai tải)	**Kém** (CA biết IP & site)	**Bảo mật tuyệt đối**
Độ trễ	Tải file định kỳ	Tăng 1 RTT mạng	**0 RTT (Tức thì)**
Xử lý sự cố	Soft-fail	Soft-fail (Rủi ro MitM)	**Hard-fail** (Must-Staple)

Hiểm Họa Của Chế Độ Soft-fail

Khi máy chủ OCSP không phản hồi, trình duyệt mặc định coi chứng chỉ vẫn hợp lệ (Soft-fail). Kẻ tấn công MitM chỉ cần chặn kết nối tới OCSP Responder là vô hiệu hóa hoàn toàn cơ chế thu hồi!

OCSP Stapling & Chuẩn OCSP Must-Staple (RFC 7633)

Nguyên lý OCSP Stapling:

- Máy chủ Web định kỳ tự truy vấn CA để lấy bản phản hồi OCSP có chữ ký hợp lệ.
- Kẹp bản phản hồi này trực tiếp vào gói tin `Certificate` trong quá trình bắt tay TLS.
- Trình duyệt không cần gửi request ra ngoài, tiết kiệm 100% độ trễ RTT.

Cờ OCSP Must-Staple:

- Phần mở rộng X.509 v3 thông báo: *"Chứng chỉ này bắt buộc phải có phản hồi OCSP kẹp kèm"*.
- Nếu kết nối TLS không có bản Staple, trình duyệt lập tức chuyển sang chế độ **Hard-fail** và ngắt kết nối!

Khuyến Nghị Vận Hành. Luôn bật cờ Must-Staple trên các dịch vụ thanh toán ngân hàng trực tuyến để khóa chặt hoàn toàn lỗ hổng Soft-fail.

3. Bảo vệ Khóa Bí mật Bằng Thiết bị Phần cứng HSM

Bốn Cấp Độ An Toàn Của Chuẩn NIST FIPS 140-3

Cấp Độ	Yêu Cầu Cơ Bản	Cơ Chế Bảo Vệ Vật Lý
Level 1	Mật mã phần mềm tiêu chuẩn	Không yêu cầu cơ chế chống can thiệp phần cứng đặc thù.
Level 2	Bằng chứng can thiệp (Tamper Evidence)	Vỏ bọc niêm phong (Tem niêm phong vỡ khi bị bóc mở).
Level 3	Chống can thiệp (Tamper Resistance)	Mạch cảm biến phát hiện cạy mở; tự xóa khóa nhạy cảm.
Level 4	Phong tỏa môi trường (Tamper Detection)	Cảm biến nhiệt độ, điện áp, tia X; kích hoạt **Zeroization** tức thì!

Beyond · Critical Pitfall to Avoid. Không bao giờ lưu khóa bí mật của Root CA hoặc Issuing CA dưới dạng tệp tin `.key` không mã hóa trên ổ cứng máy chủ thông thường. Bắt buộc phải lưu trong thiết bị HSM đạt tối thiểu FIPS 140-3 Level 3!

Chuẩn Giao Tiếp PKCS#11 & Thực Hành Với SoftHSMv2

```
# 1. Khoi tao Token trong SoftHSMv2 gia lap HSM phan cung
softhsm2-util --init-token --slot 0 --label "KMA-Root-Token" \
  --so-pin 12345678 --pin 1234

# 2. Sinh cap khoa RSA-4096 truc tiep ben trong HSM qua OpenSSL engine
openssl genpkey -engine pkcs11 -algorithm RSA \
  -pkeyopt rsa_keygen_bits:4096 \
  -out "pkcs11:token=KMA-Root-Token;object=root-key;type=private"

# 3. Kiem tra: Khoa rieng bi mat KHONG BAO GIO roi khoi HSM!
pkcs11-tool --module /usr/lib/softhsm/libsofthsm2.so -l --pin 1234 -O
```

Nguyên Lý Bất Xuất Khóa. Phần cứng HSM chỉ tiếp nhận dữ liệu hash từ máy chủ gửi vào, thực hiện phép tính ký số bằng bộ vi xử lý mật mã nội bộ và trả về chữ ký σ. Khóa bí mật không bao giờ có thể bị copy hay đọc ra ngoài!

Bài Tập Tự Kiểm Tra Buổi S04

Câu Hỏi Thẩm Định Năng Lực.

1. **Câu 1:** Một cuộc tấn công Man-in-the-Middle có thể ép trình duyệt chấp nhận chứng chỉ đã bị thu hồi bằng cách nào nếu website không bật Must-Staple?
   Giải đáp: Kẻ tấn công chặn các gói tin DNS và HTTP gửi tới máy chủ OCSP Responder của CA. Trình duyệt không kết nối được OCSP sẽ tự động chuyển sang chế độ Soft-fail và chấp nhận chứng chỉ giả!
2. **Câu 2:** Tính năng Zeroization trong thiết bị HSM hoạt động thế nào khi bị kẻ trộm tháo rời bo mạch?
   Giải đáp: Mạch cảm biến điện dung và cảm biến áp suất phát hiện nắp vỏ bị tháo sẽ lập tức phóng điện xóa sạch toàn bộ khóa bí mật trong bộ nhớ RAM không khả biến trước khi kẻ trộm kịp đọc dữ liệu.